

NAME: DEVIKA N	SRN: PES1UG24AM080	SECTION: B
----------------	--------------------	------------

DATE: 29-08-2026

Lab 1: Requirements Engineering & UML Use-Case Modelling

Objective: From a short, instructor-provided scenario, elicit key functions and constraints; write clear, verifiable functional (FR) and nonfunctional (NFR) requirements; then translate them into a UML use-case diagram and one use-case flow.

PROBLEM STATEMENT #13 | Healthcare & Telemedicine Patient
Health Record Consent Management System

Problem Context & Overview:

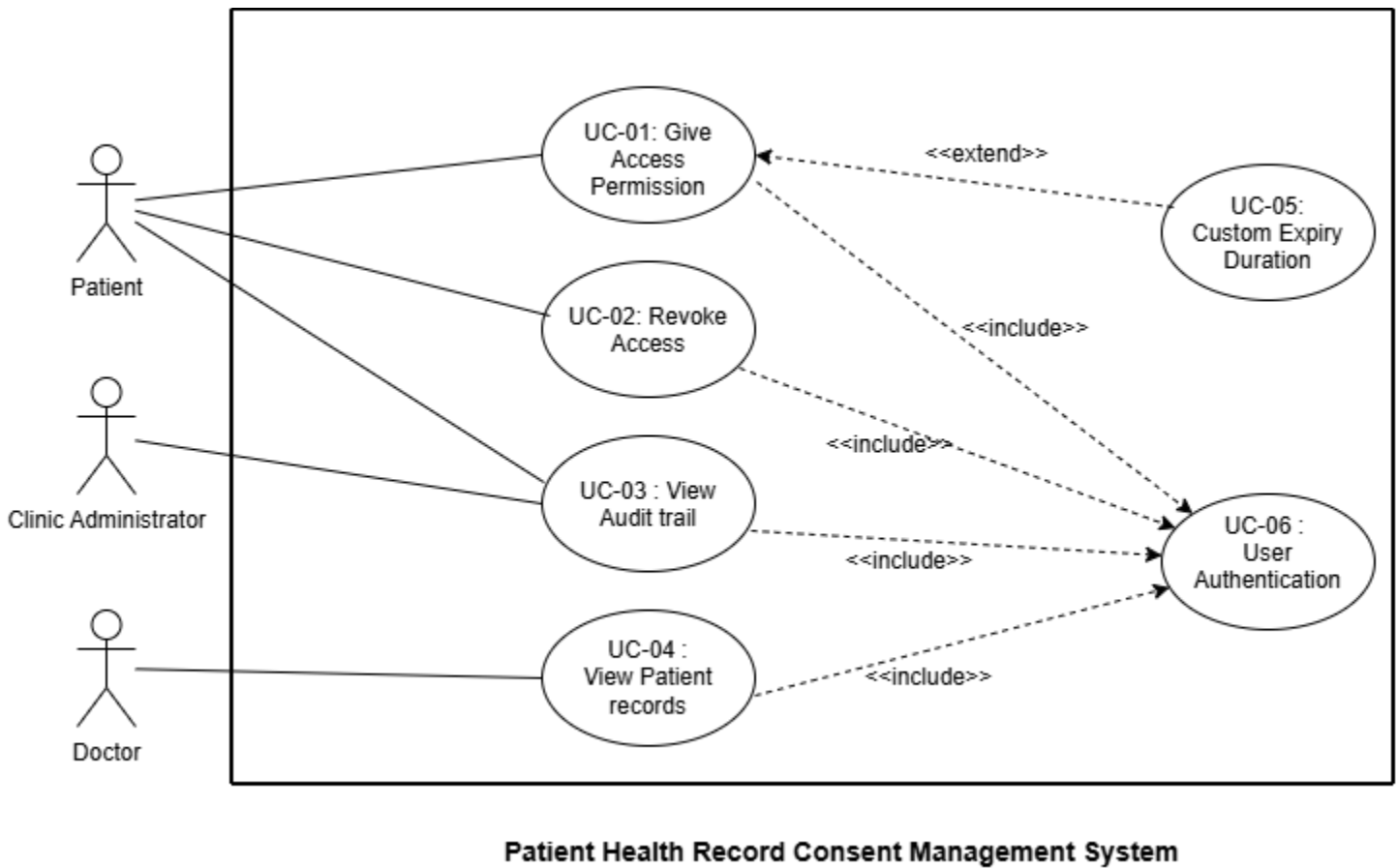
A patient-centric electronic health data gateway where patients explicitly manage granular, time-bound consent permissions for clinics, diagnostic labs, and consulting doctors to access their medical history.

Requirements Specification Table

Requirement ID	Type	Description	Priority	Acceptance Criteria	Rationale
FR-001	Functional	The system shall allow patients to grant time-bounded (e.g., 24-hour) access permissions for specific diagnostic records to verified clinic doctors.	High	Pass: Clinic access automatically revokes upon expiry timestamp. Fail: Clinic accesses records after consent expiration.	Core function of the system; gives patients granular, time-limited control over who can view their records.
FR-002	Functional	The system shall allow a patient to revoke a previously granted consent at any time before its expiry, taking effect immediately.	High	Pass: A clinic doctor's access attempt is denied within 5 seconds of revocation. Fail: Doctor can still open the record after the patient revokes access.	Patients must retain continuous control over their data, not only at the time of granting consent.
FR-003	Functional	The system shall require a clinic doctor to complete multi-factor authentication (MFA) before viewing any patient record for which consent has been granted.	High	Pass: A record-access request without a valid MFA token is rejected and logged. Fail: System displays record content without a completed MFA challenge.	Protects sensitive health data from unauthorized access even if a doctor's password is compromised.

FR-004	Functional	The system shall allow a patient to grant access to multiple diagnostic records to a single clinic doctor in one consent action, rather than requiring a separate grant per record.	Medium	Pass: Selecting 3 records and confirming once creates 3 linked access grants sharing the same expiry and audit reference. Fail: Patient must repeat the grant flow separately for each record.	Reduces friction for patients sharing a full diagnostic workup without weakening per-record traceability.
FR-005	Functional	The system shall allow a Clinic Administrator to view a read-only audit trail of all consent grant, revocation, and access events across patients in their clinic.	Medium	Pass: Administrator can filter the audit trail by patient, doctor, or date range. Fail: Any event is missing or the administrator can modify a record.	Gives clinics oversight and accountability for their doctors' access patterns, distinct from a patient's own view of their history.
NFR-001	Nonfunctional	All consent grant, revoke, and access events shall be permanently written to an append-only audit trail.	High	Pass: Benchmarking tests confirm target latency and security standards are met under simulated peak load, and no audit record can be modified or deleted. Fail: Any audit entry is altered, deleted, or missing.	Provides a tamper-proof compliance record required for healthcare data-access accountability.
NFR-002	Nonfunctional	The system shall encrypt all patient health records and consent both at rest and in transit.	High	Pass: An independent security audit confirms all stored records and metadata are encrypted with AES-256 at rest and via TLS 1.2+ in transit. Fail: Any record is found unencrypted at rest or in transit.	Protects sensitive health information from breaches and supports compliance with healthcare data-protection regulations.

Use case Modelling



Use-Case Flow Specification

Use Case Name: UC-02: Revoke Access

Primary Actor: Patient

Includes: UC-06 - User Authentication

Preconditions

1. The patient is logged in and has a registered, identity-verified account.
2. At least one active (non-expired, non-revoked) access grant exists for the patient's records.
3. The access grant is currently visible to the patient on the "Manage Consent" dashboard.

Postconditions

1. The selected access grant's status is changed to "Revoked," and its effective end time is set to the revocation timestamp.
2. The revocation event is written to the append-only audit trail.
3. The clinic doctor's system access to the specified record(s) is denied immediately, prior to the original scheduled expiry.

Main Success Scenario

1. Patient logs in and selects "Manage Consent" from the dashboard (includes UC-06: User Authentication).
2. System displays a list of all active access grants, including grantee name, record type, and time remaining until expiry.
3. Patient selects the specific access grant to revoke and taps "Revoke Access."
4. System displays a confirmation prompt summarizing the grant details (clinic doctor, record, original expiry).
5. Patient confirms the revocation.
6. System immediately invalidates the access token associated with the grant and updates its status to "Revoked."

7. System records the revocation event, including timestamp and reason in the audit trail.
8. System displays a confirmation message to the patient and sends a notification to the clinic doctor that access has ended.
9. Use case ends successfully.

Alternate Flow – 3a: Grant Already Expired

- 3a1. Patient selects a grant to revoke, but the grant's expiry timestamp has already passed
- 3a2. System detects the grant is no longer active and displays a message: "This access has already expired — no action needed."
- 3a3. System does not create a revocation event, since access was already terminated by expiry rather than by patient action.
- 3a4. Patient returns to the "Manage Consent" dashboard, which now reflects the updated (non-active) status of the grant.

Alternate Flow – 6a: Clinic Doctor Mid-Session Access

1. 6a1. The clinic doctor has an active session viewing the record at the moment of revocation.
2. 6a2. System force-terminates the doctor's active session for that record within 5 seconds of revocation.
3. 6a3. System logs the forced termination as a distinct audit event linked to the revocation.
4. 6a4. Flow resumes at step 7 of the main success scenario.